

SRC-0029 - Security Engineering Using Problem Frames

Domanda standard 1/4 - Qual e il problema di ricerca e qual e il contributo?

Identita, posizione analitica, contributo e confini della fonte

Identita	Denis Hatebur, Maritta Heisel, Holger Schmidt (2006), ETRICS, LNCS 3995, pp. 238-253.
Stable identifier	DOI 10.1007/11766155_17
PDF letto	SRC-0029-hatebur-heisel-schmidt-2006.pdf
SHA-256 sorgente	78f7230aa8d87613138303f28cf25261d129611f869fbf9723d9d58cc0a4a302
Tipo / evidenza	Ricerca primaria; metodo pattern-based con un solo caso illustrativo.
Classificazione	documentation_plus_model: nessun codice richiesto, ma serve un modello esplicito del contesto.

Risposta sintetica

I problem frame generici strutturano problemi software, ma non rendono espliciti attaccante, assunzioni, proprieta di sicurezza e passaggio controllato dal problema a una soluzione concreta. La fonte introduce security problem frame, concretized security problem frame e generic security protocol, organizzandoli in un metodo a tre passi.

```
security problem frame
-> concretized security problem frame
-> generic protocol + concrete mechanism
-> implementable specification
```

Contributi direttamente sostenuti

- Rappresentazione del problema di sicurezza senza anticipare la soluzione.
- Introduzione separata di requisito concretizzato e principio generico di soluzione.
- Istanziamento di protocolli generici e scelta successiva di algoritmi e parametri concreti.
- Esplicitazione di assunzioni, domain knowledge e capacita dell attaccante come basi del ragionamento.

Centralita per DDTA

La fonte e il precedente piu diretto nel corpus per mantenere distinti problema, overlay metodologico e specifica implementabile. Questa separazione sostiene una Base Analysis neutrale seguita da overlay specializzati e decisioni downstream.

Confini del contributo

- L articolo sviluppa in dettaglio l autenticazione; confidenzialita e integrita sono rimandate a un rapporto tecnico.
- Non deriva i diagrammi da documentazione eterogenea, non automatizza threat discovery e non prova completezza.
- Non presenta un verificatore formale implementato ne una valutazione comparativa controllata.

SRC-0029 - Security Engineering Using Problem Frames

Domanda standard 2/4 - Quali sono gli artefatti iniziali e come vengono rappresentati?

Input minimo, qualita, modello intermedio, elementi e relazioni

Risposta sintetica

Il metodo e pre-code ma non documentation-only. Richiede che l'analista costruisca o disponga di un contesto strutturato: macchina, domini ambientali, interfacce, fenomeni condivisi, requisiti, domain knowledge, assunzioni e threat model. La prosa grezza non e un input sufficiente dimostrato dalla fonte.

Input minimo reale e qualita

- Context diagram con macchina e domini ambientali chiaramente delimitati.
- Interfacce e fenomeni condivisi fra macchina e ambiente.
- Requisiti di sicurezza riferiti ai domini del problema.
- Decomposizione in sottoproblemi riconducibili a frame noti.
- Conoscenza di dominio e assunzioni, incluse capacita e risorse dell'attaccante.
- Catalogo di security problem frame, concretized frame e generic protocol.

Qualita non specificata: non sono definiti criteri di completezza, coerenza, freshness o analizzabilita della documentazione iniziale; non e descritta una trasformazione automatica da documenti a diagrammi.

Rappresentazioni intermedie

Context diagram	Macchina, domini ambientali e interfacce; nessuna soluzione anticipata.
Security problem diagram	Frame istanziato con SR, attaccante, assunzioni e domain knowledge.
Concretized diagram	CSR e principio di soluzione / meccanismo generico.
Generic sequence diagram	Protocollo riusabile da istanziare con domini e messaggi concreti.
Specification S	Sequence diagram concreti, algoritmo, parametri e meccanismi disponibili alla macchina.

Elementi estratti, inferiti e aggiunti

- Non risposto dalla fonte: non distingue elementi estratti da documenti, inferiti dal metodo o aggiunti dall'analista.
- In pratica, bounding del contesto, decomposizione, frame matching e threat characterization restano attivita umane.
- DDTA deve aggiungere provenance assertion-level, classificazione extracted/inferred/analyst-supplied, confidence e review state.

Compatibilita documentation-first

documentation_plus_model: i documenti possono alimentare l'analisi, ma la tecnica inizia operativamente solo dopo la costruzione di un modello esplicito del problema.

SRC-0029 - Security Engineering Using Problem Frames

Domanda standard 3/4 - Come funzionano traceability, change, automation e ruolo umano?

Procedura, obbligazioni condizionali, confine dell automazione ed evoluzione

Risposta sintetica

La fonte definisce una catena concettualmente tracciabile dal contesto alla specifica, ma non fornisce toolchain, provenance, versioning o change-impact automation. L ingegnere resta responsabile delle scelte e della validazione delle implicazioni.

Procedura ordinata

- 1. Delimitare il contesto e decomporre il problema di sicurezza.
- 2. Istanziare il security problem frame e registrare SR, assunzioni, domain knowledge e threat model.
- 3. Scegliere e istanziare il concretized frame con CSR e meccanismo generico.
- 4. Istanziare il generic protocol e scegliere algoritmi, parametri e meccanismi concreti.
- 5. Comporre i diagrammi e argomentare le obbligazioni condizionali.

```
A and D_basic and CSR => SR
A_biddable and D and S => CSR
```

Catena di traceability

```
context / domain / interface / phenomenon
-> decomposed security subproblem
-> frame instance + SR
-> assumptions + domain knowledge
-> concretized frame + CSR
-> generic protocol
-> concrete mechanism + parameters
-> specification S
```

Automazione e responsabilit  umana

Automazione riportata	Nessuna toolchain automatica o verifica formale implementata nel paper.
Decisioni umane	Bounding, decomposizione, frame selection, threat model, meccanismi, parametri e composizione.
Adeguatezza	Giudizio condizionato da assunzioni e domain knowledge; non prova globale o automatica.
Composizione	Dipendenze fra soluzioni riconosciute, ma interaction analysis fuori scope.

Change ed evoluzione

- Non risposto dalla fonte: versioni, impatto del cambiamento, stale detection, aggiornamento incrementale e sincronizzazione con codice/runtime.
- DDTA deve collegare ogni conclusione alle assunzioni e alla guidance tecnica che la sostengono.
- Un cambiamento a contesto, requisiti, capacita dell attaccante o parametri deve invalidare le conclusioni dipendenti.

Disciplina dei claim

```
conditional implication stated != implemented formal verification
traceable refinement != governed provenance
selected mechanism != secure implementation
```

SRC-0029 - Security Engineering Using Problem Frames

Domanda standard 4/4 - Quali sono risultati, limiti e rapporto con DDTA/overlay?

Evidenza, risultati negativi, validità temporale, Base Analysis e uso nella tesi

Risultati ed evidenza

Un solo caso illustrativo: controllo remoto di un desktop da PDA via Bluetooth. Il sistema è scomposto in sei sottoproblemi di autenticazione, confidenzialità e integrità, ma il percorso completo è mostrato soltanto per l'autenticazione del desktop.

Threat model	Common Evaluation Methodology: tempo, expertise, conoscenza del TOE, accesso, equipaggiamento.
Risultato	Totale 22, classificato Moderate.
Meccanismo scelto	Autenticazione a chiave pubblica con RSA 768 bit, basata su conoscenze del 2003.
Forza evidenza	Applicabilità illustrativa; nessuna misura di completezza, efficacia, costo o superiorità.

Cosa dimostra e cosa non dimostra

- Dimostra: staged refinement, assunzioni esplicite e separazione fra problema, principio generico e meccanismo concreto.
- Non dimostra: threat completeness, usabilità, accordo fra analisti, riduzione dello sforzo o sicurezza dell'implementazione.
- Risultato negativo: interaction/composition analysis, formalizzazione completa e integrazione con fasi successive restano future work.

Validità temporale

Ancora valido: problem/solution separation, assumption-bound reasoning e staged refinement. Obsoleto: RSA 768 bit e la conclusione di sicurezza associata. Da corroborare: guidance crittografica corrente, modern threat-capability models, automation, change impact e valutazioni empiriche.

Rapporto con DDTA: Base Analysis e overlay

Base Analysis	Domini, componenti/confini, attori, interfacce/flussi, requisiti, fatti, assunzioni e provenance.
Overlay SPF	Frame match, istanza del problema, SR, CSR, generic mechanism, protocollo e argomento condizionale.
Downstream	Algoritmi, parametri, sequence diagram concreti, implementazione ed evidenza successiva.

Controlli DDTA mancanti nella fonte

- Provenance assertion-level, extracted/inferred, confidence, contraddizioni e missing evidence.
- Review candidate -> proposed -> accepted/rejected per frame, requisito e meccanismo.
- Versioni, rationale, interaction conflicts e stale detection.

Uso consentito nella tesi e gap

La fonte può sostenere la separazione architetturale Base Analysis -> overlay -> specifica e il carattere assumption-bound dell'adeguatezza. Non può sostenere automazione da documenti, completezza o efficacia empirica. Resta aperta la trasformazione governata da documentazione eterogenea e versionata a un contesto affidabile, aggiornabile quando cambiano documenti, codice o runtime.